

Verify

 **Security Warning:** Work in an isolated environment (virtual machine or container). Never open unknown files on your primary machine.

Challenge Description

People keep trying to trick my players with imitation flags. I want to make sure they get the real thing! I'm going to provide the SHA-256 hash and a decrypt script to help you know that my flags are legitimate.

Additional details will be available after launching your challenge instance.

Hints

- Checksums let you tell if a file is complete and from the original distributor. If the hash doesn't match, it's a different file.
 - You can create a SHA checksum of a file with `sha256sum <file>` or all files in a directory with `sha256sum <directory>/*`.
 - Remember you can pipe the output of one command to another with `|`. Try practicing with the 'First Grep' challenge if you're stuck!
-

Tools Used

- `ssh` – Secure shell connection
 - `sha256sum` – Generate and verify SHA-256 hashes
 - `openssl` – Decrypt AES-256-CBC encrypted files
 - `grep` – Filter output lines
-

Complete Solution

Step 1: Initialize the Challenge Instance

Launch the instance on PicoCTF to receive your unique connection details and the target checksum:

```
ssh -p 54504 ctf-player@rhea.picoctf.net
Password: f3b61b38
Checksum: fba9f49bf22aa7188a155768ab0dfdc1f9b86c47976cd0f7c9003af2e20598f7
```

Note:

- The port number and password will change each time you launch the instance.
- The checksum value will also be different for each instance.

Step 2: Connect to the Remote Server

Access the environment via SSH using the provided port and credentials:

```
ssh -p 54504 ctf-player@rhea.picoctf.net
```

Expected output (fingerprint confirmation):

```
The authenticity of host '[rhea.picoctf.net]:54504 ([3.136.191.228]:54504)' can't betext
established.
ED25519 key fingerprint is: SHA256:QKdv+RGJL0UYRDM66IiGQ5dsXOX7DQFqB7umTy1h+IU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
```

Type yes to continue, then enter the password when prompted.

After successful authentication:

```
Warning: Permanently added '[rhea.picoctf.net]:54504' (ED25519) to the list of known
hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
ctf-player@rhea.picoctf.net's password:
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 6.8.0-1053-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
```

This system has been minimized by removing packages and content that are not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

```
ctf-player@pico-chall$
```

Step 3: Initial Reconnaissance

Check your current environment:

```
ctf-player@pico-chall$ id && whoami && pwd
```

Output:

```
uid=1000(ctf-player) gid=1000(ctf-player) groups=1000(ctf-player)
ctf-player
/home/ctf-player/drop-in
```

text

List all files in the current directory:

```
ctf-player@pico-chall$ ls -alh
```

Output:

```
total 20K
drwxr-xr-x 3 ctf-player ctf-player 57 Mar 12 2024 .
drwxr-xr-x 1 ctf-player ctf-player 20 May 8 11:46 ..
-rw-r--r-- 1 root      root      65 Mar 12 2024 checksum.txt
-rwxr-xr-x 1 root      root      856 Mar 12 2024 decrypt.sh
drwxr-xr-x 2 ctf-player ctf-player 8.0K Mar 12 2024 files
```

text

We have three key items:

- `checksum.txt` – Contains the reference SHA-256 hash

- `decrypt.sh` – A decryption script
- `files/` – A directory containing many potential flag files

Step 4: Examine the Provided Files

View the reference checksum:

```
ctf-player@pico-chall$ cat checksum.txt
```

Output:

```
fba9f49bf22aa7188a155768ab0dfdc1f9b86c47976cd0f7c9003af2e20598f7
```

text

Inspect the decryption script:

```
ctf-player@pico-chall$ cat decrypt.sh
```

Output:

```
#!/bin/bash
```

```
# Check if the user provided a file name as an argument
```

```
if [ $# -eq 0 ]; then
```

```
    echo "Expected usage: decrypt.sh <filename>"
```

```
    exit 1
```

```
fi
```

```
# Store the provided filename in a variable
```

```
file_name="$1"
```

```
# Check if the provided argument is a file and not a folder
```

```
if [ ! -f "/home/ctf-player/drop-in/$file_name" ]; then
```

```
    echo "Error: '$file_name' is not a valid file. Look inside the 'files' folder with  
'ls -R!'"
```

```
    exit 1
```

```
fi
```

```
# If there's an error reading the file, print an error message
```

```
if ! openssl enc -d -aes-256-cbc -pbkdf2 -iter 100000 -salt -in "/home/ctf-  
player/drop-in/$file_name" -k picoCTF; then
```

```
    echo "Error: Failed to decrypt '$file_name'. This flag is fake! Keep looking!"
```

```
fi
```

Key observation: The decryption password is picoCTF.

Step 5: List All Candidate Files

```
ctf-player@pico-chall$ ls files/
```

Output (abbreviated):

```
02kLdPvr  2EHy0UNu  3l1QZxg9  6JGob933  8pMqC98d  Bb0A4ZUF  F7pJKgt3  I7ySGmF3  text
MCFq06DD  OgbJmSs1  RGc1b7Dz  Tz1xgD5A  XmYppXhk  aAv6C6d8  caVHWehf  fM4Y8X1N
jFn9chPx  mL2zl8ME  pbXSC543  t1U1IMzc  vZ9Qc5Cg  yRSmctoR
0AEMwSHP  2HLM0yNv  3niXrkT4  7GdIoG6L  9E2Ci7r7  BjOuTdvT  FA1DL0lH  IihMQr2S
MRW8xKE7  OvH6KubA  RH4yp5nD  U6Za1XXb  Y9apvJeb  aCxWJytK  cbKOHVgV  frJix6dy
jGGKUWQ9  miUtTQRm  q2mcPs3c  t3cJ6Gfp  vZXXKL7g  ybQ7iIWc
...
87590c24  (this is the matching file we'll find)
...
```

There are many files. We need to find which one has the correct SHA-256 hash.

Step 6: Find the Matching File by Hash

Compute SHA-256 checksums for all files and filter for the reference hash:

```
ctf-player@pico-chall$ sha256sum files/* | grep
fba9f49bf22aa7188a155768ab0dfdc1f9b86c47976cd0f7c9003af2e20598f7
```

Output:

```
fba9f49bf22aa7188a155768ab0dfdc1f9b86c47976cd0f7c9003af2e20598f7  files/87590c24  text
```

✅ The file 87590c24 has the correct checksum.

Step 7: Decrypt the Valid File

Run the decryption script on the verified file:

```
ctf-player@pico-chall$ ./decrypt.sh files/87590c24
```

Output:

picoCTF{<REDACTED>}

text

Note: The actual flag is redacted here. In the real challenge, you will see the complete flag.

✅ Final Result

picoCTF{<REDACTED>}

text

🧠 Key Concepts

- **SHA-256 Checksum:** A cryptographic hash function used to verify file integrity and authenticity.
- **SSH (Secure Shell):** A protocol for secure remote access to servers.
- **AES-256-CBC:** A symmetric encryption algorithm used to encrypt sensitive data.
- **PBKDF2:** A key derivation function that makes brute-force attacks harder.
- **Pipeline (|):** A shell feature that passes the output of one command as input to another.
- **Checksum Verification:** The process of comparing a computed hash against a known good value to confirm a file hasn't been tampered with.